Compliance Annotation

TaskRunner SaaS, Inc.

Framework: SOC 2 | Compliance Level: Non-Compliant / High Risk

---

Finding 1: [VIOLATION] Governance & Security Oversight (CC1.1-CC1.3) TaskRunner lacks a formal security governance structure . There is no Chief Information Security Officer (CISO) or designated security lead, no cross-functional security committee, and no evidence of regular security posture reporting to the Board of Directors . **References:** SOC 2 CC1.1, CC1.2, CC1.3

Finding 2: [VIOLATION] Absence of Risk Management Process (CC3.1-CC3.4) The organization has no documented process for performing annual or event-driven risk assessments . The failure to identify, evaluate, and mitigate internal and external threats, including fraud risk, represents a fundamental deficiency in the control environment . **References:** SOC 2 CC3.1, CC3.2, CC3.4

Finding 3: [VIOLATION] Logical Access - MFA Deficiency (CC6.1) TaskRunner explicitly states that it does not currently require multi-factor authentication (MFA) for all users. Under SOC 2, MFA is a critical control for protecting administrative, production, and sensitive data access against credential-based attacks. **References:** SOC 2 CC6.1

Finding 4: [VIOLATION] Inadequate Password Complexity Standards (CC6.1) The policy mandates a minimum password length of only 8 characters. This standard is insufficient for protecting enterprise cloud systems and fails to meet requirements for high-entropy authentication to prevent brute-force or dictionary attacks. **References:** SOC 2 CC6.1

Finding 5: [VIOLATION] Deficient Access Review & Termination (CC6.2, CC6.3) While access is granted based on roles , the policy does not outline a formal provisioning/deprovisioning workflow . There is no requirement for quarterly access reviews or a defined timeline (e.g., 24 hours) for revoking access upon employee termination or role change . **References:** SOC 2 CC6.2, CC6.3

Finding 6: [VIOLATION] Confidentiality - Absence of Encryption at Rest (C1.1, CC6.1) The policy identifies the use of HTTPS for data in transit but is silent regarding encryption for data at rest (e.g., databases, EBS volumes, and S3 buckets) . This failure to protect stored customer data violates the core principle of confidentiality and asset protection . **References:** SOC 2 CC6.1, C1.1

Finding 7: [VIOLATION] Lack of System Monitoring & SIEM Operations (CC7.2) There is no description of security logging, centralized SIEM (Security Information and Event Management), or real-time alerting for anomalous activity . Without continuous monitoring,

the organization cannot effectively detect or respond to unauthorized access attempts or system breaches . **References:** SOC 2 CC7.2

Finding 8: [VIOLATION] Incident Response Ineffectiveness (CC7.3-CC7.5) TaskRunner does not maintain a documented Incident Response Plan (IRP) . Consequently, there are no defined severity levels, escalation procedures, or evidence of semi-annual tabletop exercises to test the organization's ability to manage security incidents . **References:** SOC 2 CC7.3, CC7.4, CC7.5

Finding 9: [VIOLATION] Change Management & Deployment Control (CC8.1) The policy describes no formal change management process . There is no evidence of mandatory peer code reviews, testing in staging environments, or Change Advisory Board (CAB) approval for production modifications, creating high risk for unauthorized or unstable changes . **References:** SOC 2 CC8.1

Finding 10: [VIOLATION] Availability - Disaster Recovery Testing Gap (A1.2) Daily backups are performed , but there is no documented Disaster Recovery (DR) or Business Continuity Plan (BCP) . The organization lacks defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) and does not perform regular recovery testing . **References:** SOC 2 A1.2

Finding 11: [VIOLATION] Supply Chain & Vendor Risk Management (CC9.2) TaskRunner utilizes AWS infrastructure and third-party coworking spaces , yet it has no formal program for assessing vendor security risk, reviewing third-party SOC 2 reports, or enforcing security-related contractual obligations . **References:** SOC 2 CC9.2

Finding 12: [VIOLATION] Privacy - Vague Retention & Disposal (P4.2) The policy states that data may be retained for a "reasonable period" after account closure. This non-specific terminology fails the SOC 2 Privacy requirement for clear, objective data retention schedules and secure disposal practices. **References:** SOC 2 P4.2

Finding 13: [VIOLATION] Workforce Security Awareness & Training (CC1.4) New hires receive a copy of the security policy , but there is no mandatory annual security training program, no phishing simulations, and no specialized secure coding training for the engineering team . **References:** SOC 2 CC1.4